Attaquer RDP _ (Remote Desktop Protocole):

On commence a connaitre RDP rappelons juste que c'est un protocole proprietaire
qui s'excicute sur le port tcp/3389, ont peux y faire plusieurs types de brutforce
et aussi du PTH comme vu dans le module Password Attack.
Du coup la je me concentre sur le Detournement de Session RDP.

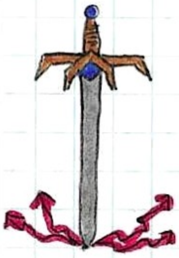
- Imaginons qu'on a reussi à accéder à une machine en RDP avec un co
pte d'administrateur local. Si un autre utilisateur est connecté en RDP
notre machine compromise on peux hijack (détourner) sa session pour élever
nos privilèges et impersonate (voler l'identité) de ce compte.

Pour énumérer les utilisateurs connecté à la machine on à la commande:
`\Rtb> query user` ↳ elle permet aussi de récuperer les Session ID pour le hijack

C'est le binnair tscon.exe qui permet aux utilisateurs de se connecter à une
autre section de bureau mais il nécessite des privilèges SYSTEM On va donc
demander à windows de créer un Service (programme qui tourne en arrière
plan et appartient par default à SYSTEM).

```
C:\Rtb> sc create evilsessionname binpath= "cmd.exe /k tscon iddelasessionci
/dest: nom(pasID)denotresessionactuelle
C:\Rtb> net start evilsessionname
```

NB: Cette Methode Ne fonctionne Plus à Partir de Windows Server 2019.



Attaquer le DNS _ (System de Nom de Domaine):

On a déja longuement parle du DNS et abordé l'attaque de transfert de zone dan
le module Info-Gathering Web ici on va juste expliquer quelques attaques sup
plementaires

- Subdomain takeover : ou prise de controle de sous domain _ 1_ Une entreprise
pointe un sous domain vers un service tiers (Github, AWS.) via enregistrement
DNS _ 2 L'entreprise supprime son compte tiers mais oublie de supprimer l'en
gistrement le pointer deviens orphelin. L'attaquant va sur le service tiers crée un
compte et s'approprie ce sous domaine (Ex: en le nommant exactement pour l
buckets AWS, ou en précisant exactement le CustomDomain sur un project gith

- Cache Poisonning : empoisonnement de cache on va voir l'attaque sur un rés
local car elle est devenue impossible en distante ou presque... L'attaquant inter
cepte la communication entre un utilisateur et un serveur DNS pour rediriger
son trafic en ligne vers un site web frauduleux. On peux utiliser des outils com
me Bettercap ou Ettercap pour mener l'attaque
Pour ettercap on doit d'abord modifier le fichier /etc/ettercap/etter.dns pour fa
correspondre le domaine cible A l'ip attaquant. Ensuite on scan les hotes actif
du réseau avec hosts > Scan for hosts on ajoute l'ip de la cible à Target1 et celle
de la passerelle à Target2.
Puis dans Plugins > Manage Plugins on active l'attaque dns_spoof, à la
fin de l'attaque la victim se connectant au domaine verra une fausse page héber-
geé par notre IP. Note il y aura une alerte sur les sites https et un blocage complet
sur les sites protégé par HSTS (ex google.com). pour verifier on peux faire un curl-
si on a pas de Strict-Transport-Security l'alerte sera contournable.

On en ligne de commande après biensur avoir lancer un serveur python avec --bin
notre ip pour forcer l'écoute sur notre ip et en ayant un index.html pour le site

```
Agentpathogene@parrot ~$ sudo ettercap -T -q -M arp:remote -P dns_spoof
/targetIPto spoof// /passerelle/
```